

APT41 — Brass Typhoon

Threat Actor Profile | Aviation & Aerospace

Published: 2026-05-29 | Profile ID: LBC-AP-2026-005 | TLP: AMBER

Prepared by: Lost Boys Cyber — Threat Intelligence Team

AI-ASSISTED REPORT — IMPORTANT DISCLOSURE

This profile was generated with AI assistance. All TTPs, IOCs, attribution assessments, and detection rules must be independently validated by a qualified analyst before operational use, external distribution, or legal/regulatory action.

Attribution Warning: Nation-state attribution is probabilistic. Confidence levels reflect analytical assessment only — not proof.

1. At a Glance

Attribute	Value
Primary Alias	APT41
MITRE ATT&CK Group	G0096 — https://attack.mitre.org/groups/G0096/
Nation-State Sponsor	China — Ministry of State Security (MSS)
Motivation	Dual mandate: state espionage (aerospace IP theft) + financial crime (ransomware, fraud)
Active Since	2012 (confirmed)
Activity Status	Active
Sophistication	Nation-state — among the most capable Chinese APT groups; zero-day exploitation history
Primary Sectors	Aerospace, Defence, Telecom, Healthcare, Technology, Gaming, Logistics, Utilities
Primary Geographies	US, UK, Germany, Italy, Spain, Taiwan, Thailand, Turkey, Southeast Asia — 14+ countries
Assessment Confidence	High — US DOJ indictment (2020); multiple independent vendor corroboration

2. Identity & Aliases

Vendor	Designation
Mandiant / Google	APT41
Microsoft	Brass Typhoon (formerly BARIUM)
CrowdStrike	Wicked Panda
Recorded Future	RedGolf
ESET	Winnti Group (partial overlap)
MITRE ATT&CK	G0096
DOJ / FBI	Named in September 2020 indictment — five Chinese nationals charged

3. Attribution Assessment

Assessment: China — MSS-directed. Confidence: High.

APT41 attribution rests on the strongest public evidentiary base of any Chinese APT group: a September 2020 US Department of Justice indictment naming five Chinese nationals as operators. Attribution is

independently corroborated by Mandiant, CrowdStrike, Microsoft, and ESET across hundreds of documented intrusions in 14+ countries. The group's dual mandate (state espionage + personal financial gain) is unusual and well-documented — suggesting MSS operators run freelance criminal operations alongside their state duties.

For aerospace targeting, APT41's espionage objective is unambiguous: acquisition of advanced manufacturing processes, defence system specifications, and aviation technology to reduce China's technological development timeline. Supply chain attacks provide scalable access to multiple downstream targets from a single compromise.

Evidence Type	Detail	Confidence
DOJ indictment	September 2020 indictment names 5 operators; charges include CFAA violations across 14 countries	High
Targeting alignment	Aerospace, defence tech, IP-rich sectors align with Made in China 2025 and military modernisation goals	High
Tool exclusivity	KEYPLUG, DUSTPAN, DUSTTRAP are exclusive to APT41; not observed in other actor campaigns	High
Dual mandate	Personal financial crime (gaming, crypto) alongside state espionage — unique MSS contractor profile	High
Cross-vendor corroboration	Mandiant, CrowdStrike, Microsoft, ESET independently attribute this cluster	High

4. Background & History

APT41 (Brass Typhoon) is unique among Chinese state actors for combining a formal MSS espionage mandate with personal financial crime operations — running both simultaneously. For aerospace, the group pursues advanced manufacturing IP, defence system specifications, and aviation technology through a combination of direct intrusion and supply chain compromise.

The group's most significant operational characteristic is speed: APT41 weaponises newly disclosed CVEs within days of public release, giving defenders minimal patch window. Their 2022 Log4Shell exploitation to deploy KEYPLUG on Linux systems began within 24 hours of the vulnerability's disclosure. In 2024–2025, the group demonstrated new techniques including Google Calendar C2 (abusing the legitimate Google Calendar API to blend C2 traffic with enterprise cloud usage) and continued Fortinet exploitation for KEYPLUG deployment.

Date	Event	Significance
2012	First observed	Earliest documented APT41

		activity; gaming and tech targeting
2017–2019	Aerospace IP campaign	Systematic IP theft from Western defence contractors
2019–2020	Supply chain operations	Trojanised software updates reaching aerospace clients downstream
Sep 2020	DOJ indictment	5 Chinese nationals charged; unprecedented public attribution
2022	Log4Shell (KEYPLUG on Linux)	CVE weaponised within 24h; Linux KEYPLUG variant deployed
2024	Fortinet + DUSTPAN campaigns	Aerospace and logistics targeting; BEACON via DUSTPAN dropper
Apr 2025	Google Calendar C2	Novel C2 technique abusing Google Calendar API
2025	Ongoing global campaigns	Continued aerospace IP theft; Southeast Asia, Europe, North America

5. TTPs — MITRE ATT&CK

Tactic	Technique	Observed	Frequency	Notes
Initial Access	T1190 — Exploit Public-Facing App	Yes	High	Rapid zero-day/n-day: Log4Shell, Fortinet, Exchange, Citrix
Initial Access	T1566.001 — Spearphishing	Yes	Med	Targeted aerospace engineers and procurement staff
Initial Access	T1195.002 — Supply Chain	Yes	High	Trojanised software updates; downstream aerospace impact
Execution	T1059.001 — PowerShell	Yes	High	Post-exploitation execution
Persistence	T1505.003 — Web Shell	Yes	High	ANTSWORD, BLUEBEAM web shells on compromised servers

Persistence	T1547.001 — Registry Run Keys	Yes	Med	Persistence for dropped payloads
Defence Evasion	T1027 — Obfuscated Files	Yes	High	Encrypted BEACON payloads; DUSTPAN in-memory loading
Defence Evasion	T1102.002 — Cloud Services C2	Yes	High	Google Calendar C2 (2025); legitimate API abuse
Credential Access	T1003.001 — LSASS Memory	Yes	High	Credential dumping post-compromise
Lateral Movement	T1021.002 — SMB Admin Shares	Yes	High	Internal lateral movement post-foothold
Collection	T1005 — Data from Local System	Yes	High	Aerospace IP: engineering drawings, specifications
Exfiltration	T1048 — Exfil Alt Protocol	Yes	Med	Custom encrypted channels; cloud storage exfil

6. Toolset

Tool	Type	Purpose	Attribution Confidence
KEYPLUG	C++ Backdoor (Linux+Win)	Primary espionage backdoor; modular; multi-protocol C2	High — exclusive to APT41
DUSTPAN	In-memory dropper	Decrypts and executes payload entirely in memory; no disk artefact	High — exclusive
DUSTTRAP	Second-stage implant	Hands-on-keyboard capability; advanced post-exploitation	High — exclusive
ShadowPad	Modular backdoor	Shared with other MSS groups; plugin architecture	Med — shared MSS tooling

PlugX	RAT	Long-running Chinese espionage RAT; widely shared across APTs	Low — broad sharing
BEACON (Cobalt Strike)	Commercial C2	Post-exploitation; deployed via DUSTPAN	Low — commodity
ANTSWORD / BLUEBEAM	Web shells	Server-side persistence and pivot point	Med

7. Detection

7.1 Sigma — DUSTPAN In-Memory Injection

```

title: APT41 — Suspicious In-Memory Payload Execution (DUSTPAN Pattern)
id: c1d2e3f4-a5b6-7890-cdef-456789010005
status: experimental
description: Process injection into svchost/rundll32 from non-system source —
DUSTPAN loading BEACON
references:
  - https://attack.mitre.org/groups/G0096/
  - https://cloud.google.com/blog/topics/threat-intelligence/apt41-arisen-from-dust
author: Lost Boys Cyber | date: 2026-05-29
tags:
  - attack.defense_evasion
  - attack.t1055
logsource:
  category: process_access
  product: windows
detection:
  selection:
    GrantedAccess|contains:
      - "0x1ffffff"
      - "0x1f0fff"
    TargetImage|endswith:
      - "\svchost.exe"
      - "\rundll32.exe"
      - "\dllhost.exe"
  filter:
    SourceImage|startswith:
      - "C:\Windows\System32\"
      - "C:\Program Files\Windows Defender\"
      - "C:\ProgramData\Microsoft\Windows Defender\"
  condition: selection and not filter
falsepositives:
  - Legitimate security tooling (AV/EDR); validate SourceImage carefully
level: high

```

7.2 Sigma — ANTSWORD Web Shell

```

title: APT41 — ANTSWORD/BLUEBEAM Web Shell Activity
id: c2d3e4f5-a6b7-8901-defa-567890120006
status: experimental
description: Web server process spawning cmd/powershell — web shell execution
pattern
tags:

```

```

- attack.persistence
- attack.t1505.003
logsource:
  category: process_creation
  product: windows
detection:
  selection:
    ParentImage|endswith:
      - "\w3wp.exe"
      - "\httpd.exe"
      - "\nginx.exe"
    Image|endswith:
      - "\cmd.exe"
      - "\powershell.exe"
      - "\whoami.exe"
      - "\net.exe"
  condition: selection
falsepositives:
  - Legitimate web application deployment scripts; validate CommandLine
level: high

```

7.3 KQL — Google Calendar C2 Detection (2025)

```

// APT41 2025: Non-browser process making requests to Google Calendar API
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has "calendar.google.com"
  or RemoteUrl has "googleapis.com/calendar"
| where InitiatingProcessFileName !in~ (
  "chrome.exe", "msedge.exe", "firefox.exe", "outlook.exe",
  "teams.exe", "slack.exe")
| project Timestamp, DeviceName, AccountName,
  InitiatingProcessFileName, RemoteUrl, RemoteIP
| order by Timestamp desc

```

7.4 KQL — Rapid CVE Exploitation: Edge Appliance Shell

```

// APT41: Web shell dropped on Fortinet/Exchange/Citrix within days of patch
release
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has_any
("inetpub", "wwwroot", "fortigate", "citrix", "exchange", "owa")
| where FileName endswith ".aspx" or FileName endswith ".php" or FileName endswith
".jsp"
| where InitiatingProcessFileName !in~ ("w3wp.exe", "iisexpress.exe", "httpd.exe")
| project Timestamp, DeviceName, FolderPath, FileName, InitiatingProcessFileName
| order by Timestamp desc

```

8. Threat Hunting

8.1 Hunt: KEYPLUG C2 Beaconsing

Hypothesis: KEYPLUG uses multiple protocols (HTTP/S, TCP, UDP) with consistent beaconing intervals. Hunt for non-browser HTTPS connections to unusual cloud endpoints with regular timing.

```

DeviceNetworkEvents
| where Timestamp > ago(90d)
| where RemotePort == 443

```

```
| where InitiatingProcessFileName !in~ (  
|   "chrome.exe","msedge.exe","firefox.exe","outlook.exe","teams.exe",  
|   "onedrive.exe","sharepoint.exe","svchost.exe")  
| summarize Count=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp)  
|   by DeviceName, RemoteIP, RemoteUrl, InitiatingProcessFileName  
| where Count > 100  
| order by Count desc
```

9. Recommended Defensive Posture

- Patch edge appliances within 72 hours of CVE disclosure — APT41 weaponises vulnerabilities in Fortinet, Citrix, Exchange within days; this is the single highest-impact hardening action.
- Protect the software supply chain — validate integrity of all software updates; implement code signing verification; maintain SBOM for all third-party software in the aerospace environment.
- Deploy web shell detection on internet-facing servers — ANTWORD/BLUEBEAM are the primary server-side persistence mechanism; file integrity monitoring on web directories is essential.
- Monitor non-browser HTTPS and cloud API usage — KEYPLUG and the Google Calendar C2 technique both produce unusual outbound HTTPS; deploy application-layer monitoring for non-standard cloud API calls.
- Implement memory protection / process injection detection — DUSTPAN's in-memory loading produces no disk artefact; EDR behavioural detection of process injection is the primary detection mechanism.
- Hunt for web shells immediately after any published CVE affecting your internet-facing appliances — APT41's exploitation timeline means you may have a compromise before patches are available.

10. References

- [1] MITRE ATT&CK. "APT41 — G0096." <https://attack.mitre.org/groups/G0096/>
- [2] Mandiant/Google Cloud. "APT41 Has Arisen From the DUST." <https://cloud.google.com/blog/topics/threat-intelligence/apt41-arisen-from-dust>
- [3] US DOJ. "Seven International Cyber Defendants Charged." September 2020.
- [4] The Hacker News. "APT41 Exploits Google Calendar for C2." <https://thehackernews.com/2025/05/chinese-apt41-exploits-google-calendar.html>
- [5] Fortinet. "APT41 Threat Actor Profile." <https://www.fortiguard.com/threat-actor/5566/apt41>
- [6] Brandefense. "APT41: China's Dual-Purpose Cyber Powerhouse." <https://brandefense.io/blog/apt41-2025/>